

МІНІСТЕРСТВО ОСВІТИ І НАУКИ УКРАЇНИ
НАЦІОНАЛЬНИЙ УНІВЕРСИТЕТ «ПОЛТАВСЬКА ПОЛІТЕХНІКА
ІМЕНІ ЮРІЯ КОНДРАТЮКА»

Навчально-науковий інститут інформаційних технологій і робототехніки
Кафедра комп'ютерних та інформаційних технологій і систем

Лабораторна робота № 4

з навчальної дисципліни

"Технології розробки корпоративних Web-додатків"

Виконав:

Студент 402 – ТН

Марков Іван Андрійович

Перевірив:

Тютюнник Петро Богданович

Полтава 2026

Лабораторна робота №4

Реалізація підсистеми безпеки, автентифікації та авторизації

Завдання

Мета роботи - захистити API від несанкціонованого доступу, реалізувати механізм реєстрації та входу користувачів, а також розмежувати права доступу на основі ролей.

1. Реалізація моделі користувача та безпечного зберігання паролів

- Розширте базу даних сутністю User (Користувач) та Role (Роль), якщо їх ще немає.
- Вимога: Паролі користувачів заборонено зберігати у відкритому вигляді.
- Реалізуйте механізм хешування паролів перед збереженням у БД (використовуйте алгоритми BCrypt, Argon2 або PBKDF2).
- Реалізуйте ендпоінт для реєстрації нового користувача (Sign Up), який приймає логін/email та пароль, хешує пароль і зберігає користувача в БД.

2. Реалізація автентифікації (Authentication)

- Реалізуйте механізм входу в систему (Sign In).
- Створіть сервіс, який перевіряє валідність наданих облікових даних (порівнює хеш введеного пароля з хешем у БД).
- Оберіть механізм управління сесією. Для REST/GraphQL API рекомендовано використовувати JWT (JSON Web Tokens):
 - При успішному вході сервер має генерувати підписаний токен (Access Token), який містить ID користувача та його Role.
 - Токен має мати обмежений термін дії (наприклад, 15-60 хвилин).

3. Реалізація авторизації (Authorization) та Middleware

- Реалізуйте механізм перехоплення запитів (Middleware, Interceptor або Filter), який перевіряє наявність та валідність токена в заголовках запиту (зазвичай Authorization: Bearer <token>).
- Захистіть маршрути (Endpoints) вашого API:

- Public routes: Доступні всім (наприклад, реєстрація, логін, перегляд списку товарів).
- Authenticated routes: Доступні тільки авторизованим користувачам (наприклад, створення замовлення, редагування профілю).
- Admin routes: Доступні тільки користувачам з роллю Admin (наприклад, видалення товарів, керування користувачами).

4. Інтеграція з поточним API

- Модифікуйте контролери з Лаб №3.
- Спробуйте виконати запит до захищеного ресурсу без токена і переконайтеся, що отримуєте помилку 401 Unauthorized.
- Спробуйте виконати запит до адміністративного ресурсу зі звичайним користувачем і переконайтеся, що отримуєте помилку 403 Forbidden.

Очікуваний результат (Звіт та код):

1. Посилання на Git-репозиторій.
2. Скріншоти з Postman/Swagger:
 - a. Успішна реєстрація (створення користувача).
 - b. Успішний логін (отримання JWT токена у відповідь).
 - c. Знімок БД, де видно, що поле Password містить хеш, а не відкритий текст.
 - d. Запит без токена -> статус 401 Unauthorized.
 - e. Запит з токеном звичайного юзера до адмін-панелі -> статус 403 Forbidden.
 - f. Успішний запит до захищеного ресурсу з валідним токеном.

Хід роботи

Посилання на PR:

https://github.com/BanditFromSiege/TRVD_2026_402_TN_Markov_Labs/pull/4

Скріншоти з Swagger.



Рисунок 1 – Методи всіх контролерів.

Пункт а.

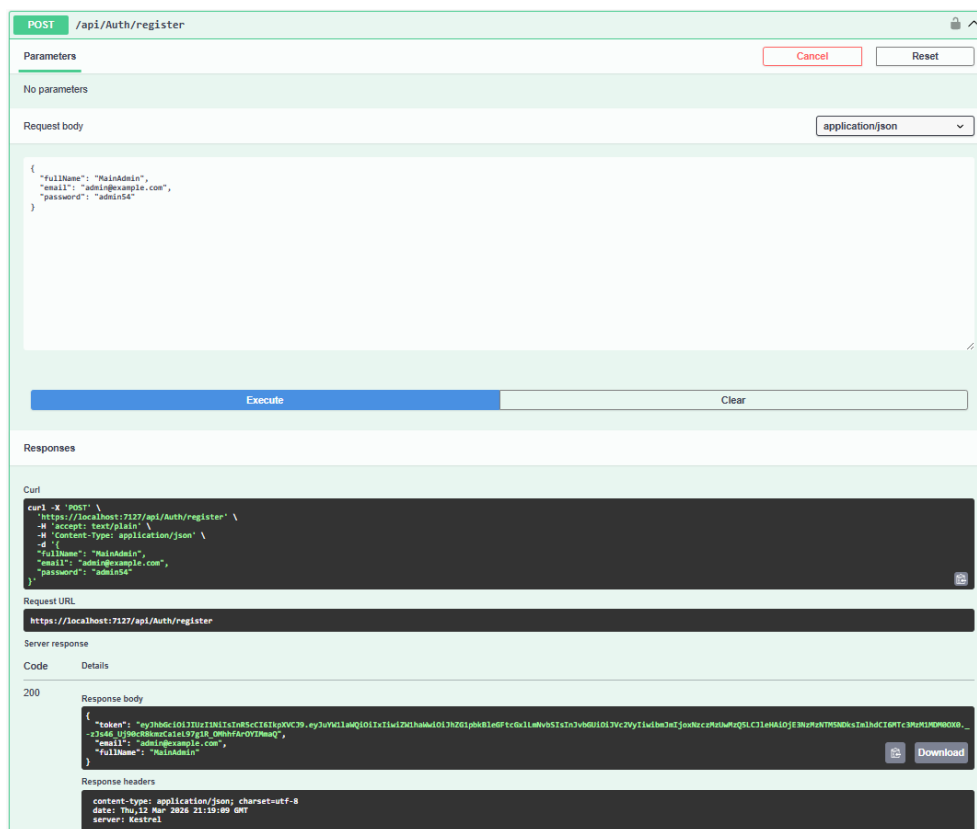


Рисунок 2 – Реєстрація користувача, який потім стане адміном.

Пункт б.

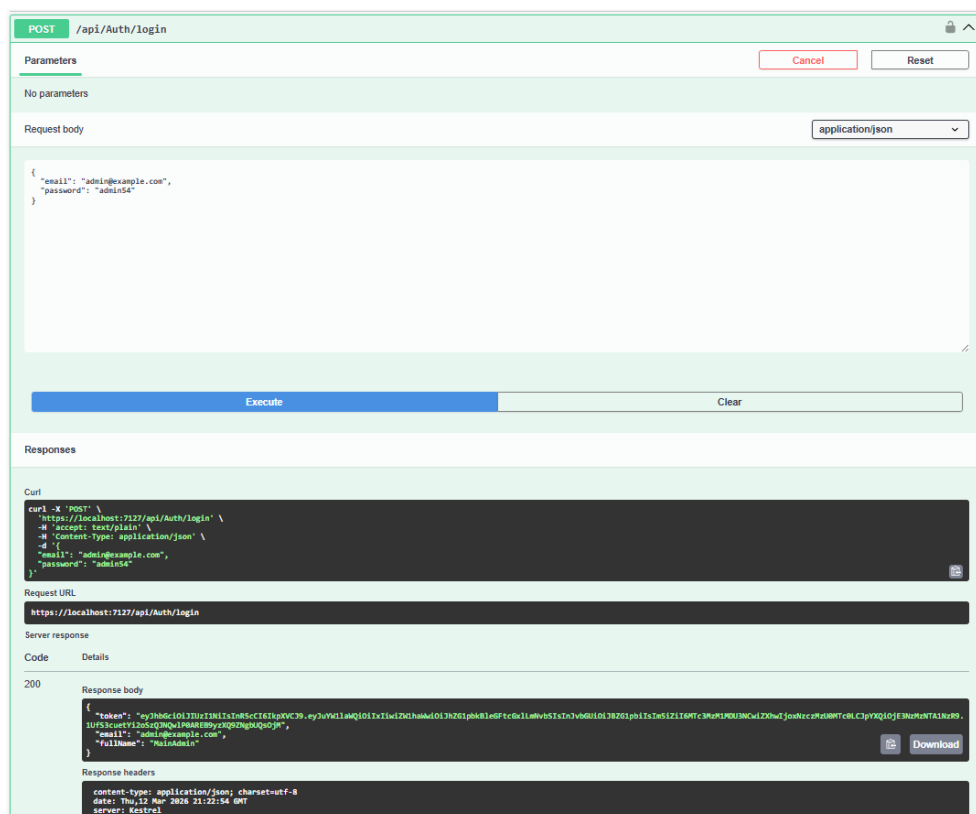


Рисунок 3 – Логін користувача, який потім стане адміном.

Available authorizations

Bearer (apiKey)

JWT Authorization header using the Bearer scheme. Enter 'Bearer' followed by your token.

Name: Authorization

In: header

Value:

Bearer eyJhbGciOiJIUzI1NiIs

Authorize

Close

Рисунок 4 – Введення токена користувача.

Available authorizations

Bearer (apiKey)

Authorized

JWT Authorization header using the Bearer scheme. Enter 'Bearer' followed by your token.

Name: Authorization

In: header

Value: *****

Logout

Close

Рисунок 5 – Авторизація токена користувача.

Пункт с.

Database Structure

Browse Data

Edit Pragmas

Execute SQL

Таблиця: Users

Filter in any column

	Id	FullName	Email	PasswordHash	RoleId	CreatedAt
Фи...	Фильтр	Фильтр	Фильтр	Фильтр	Фильтр	Фильтр
1	1	MainAdmin	admin@example.com	\$2a\$11\$sU7Q/yET7XWF8azdXaVlgOyvCcUyAgL2mjPzvG10EPf.J72i/5ZFi	1	2026-03-12 21:19:08.8496065

Рисунок 6 – Таблиця користувачів у базі даних.

Таблиця: Users

Filter in any column

	Id	FullName	Email	PasswordHash	RoleId	CreatedAt
Фи...	Фильтр	Фильтр	Фильтр	Фильтр	Фильтр	Фильтр
1	1	MainAdmin	admin@example.com	\$2a\$11\$sU7Q/yET7XWF8azdXaVlgOyvCcUyAgL2mjPzvG10EPf.J72i/5ZFi	3	2026-03-12 21:19:08.8496065

Рисунок 7 – Користувач, зі зміненою роллю.

Пункт d.

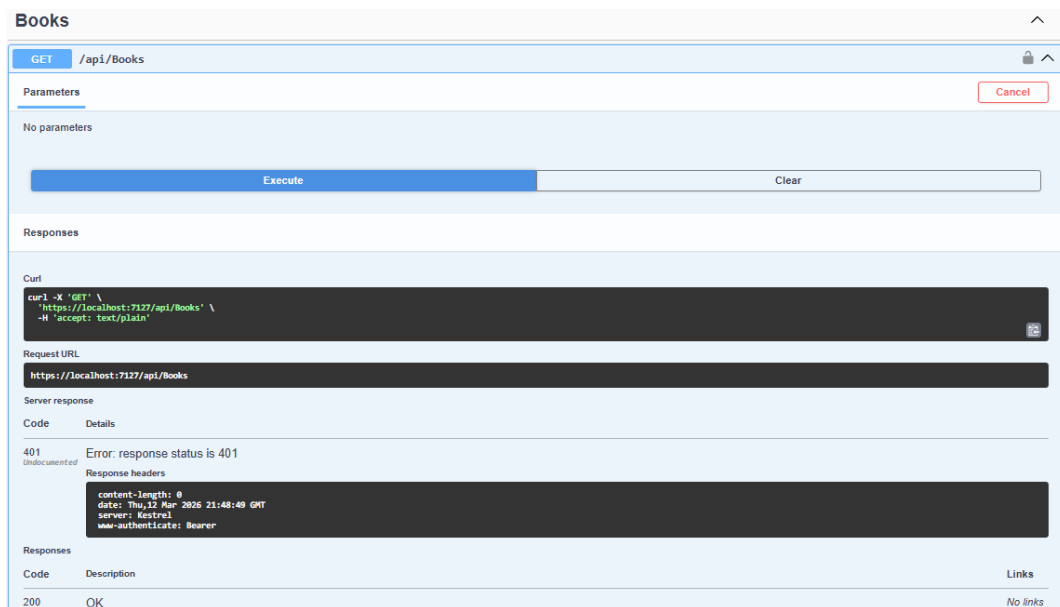


Рисунок 8 – Спроба виконати запит, без авторизації.

Пункт е.

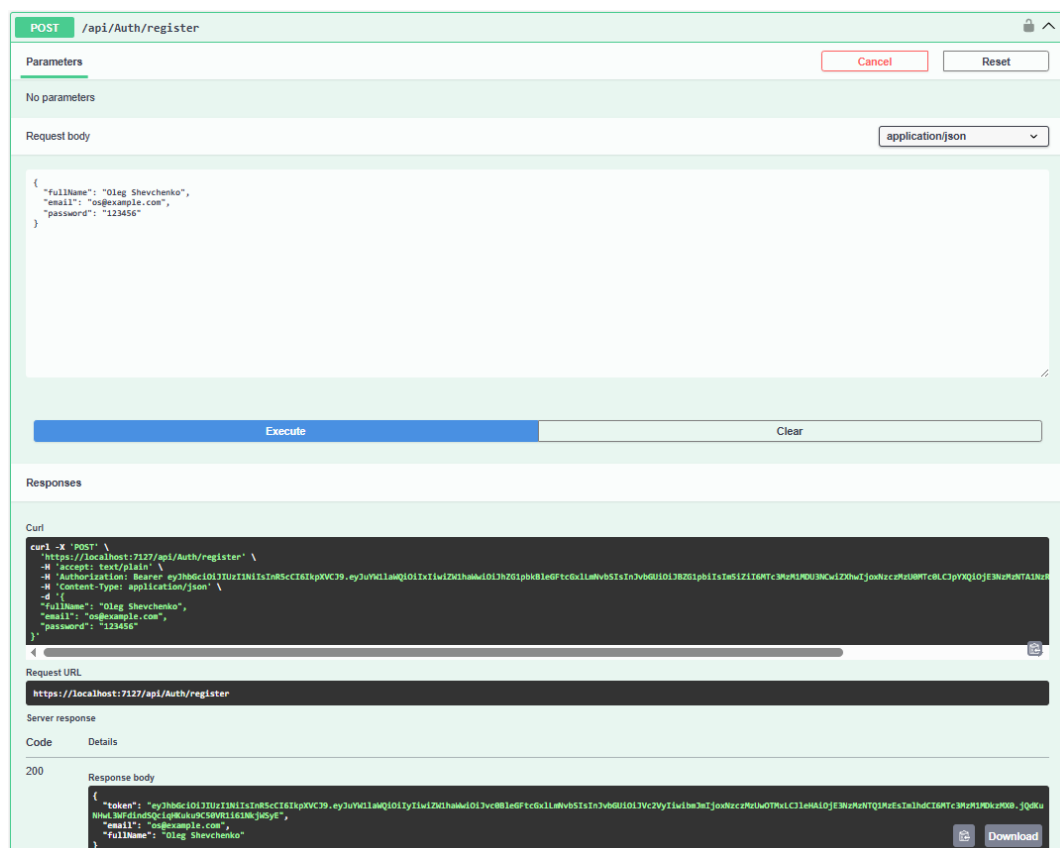


Рисунок 9 – Створення нового користувача зі звичайною роллю.

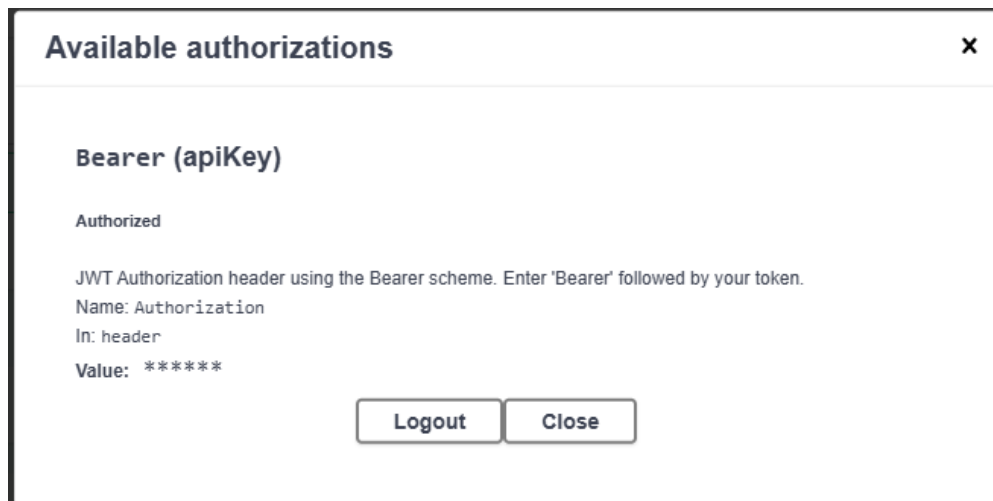


Рисунок 12 – Авторизація адміна.

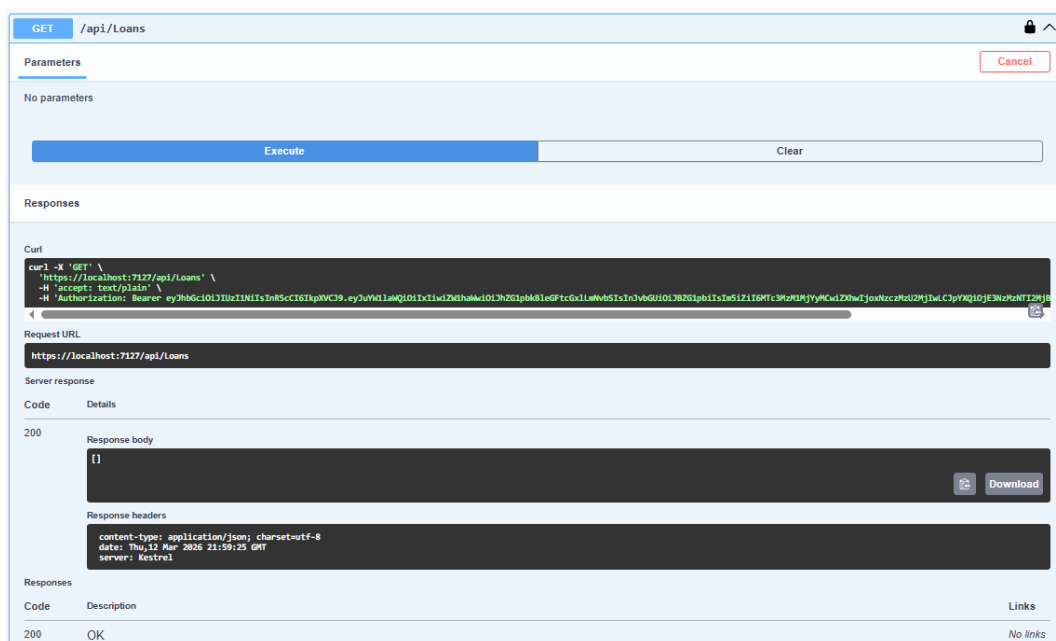


Рисунок 13 – Виконання запиту користувачем, який має права це робити.